

MegaTravel Threat & Mitigation Analysis (STRIDE)

Scope: Web platform (clients, APIs), payment processing, booking engine, internal services, DB.

Methodology: STRIDE (Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege).

1. Spoofing Identity

Threat: Attackers impersonate users or services (phishing, credential stuffing, API key theft).

Impact: Unauthorized bookings, fraud, data access.

Mitigations: - MFA for users and admins - OAuth2 / strong session management - API authentication (mTLS, signed tokens) - Rate limiting & anomaly detection

2. Tampering with Data

Threat: Modification of booking data, prices, or transactions (MITM, injection attacks).

Impact: Financial loss, corrupted bookings.

Mitigations: - TLS everywhere (HTTPS, internal encryption) - Input validation & parameterized queries - Integrity checks (hashing, signing) - WAF protection

3. Repudiation

Threat: Users deny actions (booking, cancellation, payments).

Impact: Disputes, legal issues.

Mitigations: - Centralized logging (immutable logs) - Audit trails with timestamps & IDs - Digital signatures for critical actions

4. Information Disclosure

Threat: Leakage of personal data, payment info, travel plans.

Impact: GDPR violations, reputational damage.

Mitigations: - Data encryption at rest (AES-256) - Access control (RBAC, least privilege) - Tokenization of payment data - Secure secrets management

5. Denial of Service (DoS)

Threat: Traffic floods disrupt booking services.

Impact: Downtime, revenue loss.

Mitigations: - DDoS protection (CDN, rate limiting) - Auto-scaling infrastructure - Circuit breakers, caching

6. Elevation of Privilege

Threat: Attackers gain admin/system privileges (exploits, misconfigurations).

Impact: Full system compromise.

Mitigations: - Strict IAM policies - Regular patching & vulnerability scanning - Network segmentation (DMZ, internal zones) - Zero Trust architecture

Conclusion: Applying layered defenses (authentication, encryption, monitoring, and least privilege) reduces risk across all STRIDE categories while maintaining scalability and compliance.